

 Hive Pro[®]

The background of the entire slide features a dark red, textured surface with a network of glowing orange lines and dots, resembling a digital globe or a complex data network.

HiveForce Labs

Celebrity Vulnerabilities and Cyber Resilience: Navigating Challenges with HivePro Uni5

CELEBRITY VULNERABILITY CATALOG

REPORT BY
HiveForce Labs

REPORT GENERATED ON
September 14, 2023 // 09:00 PM

Table Of Contents

Defending The Spotlight	04
Decoding Celebrity Vulnerabilities & understanding their Impact	05
The Timeline	06
Challenges Possessed by Celebrity Vulnerabilities	07
Insights	08
Exploring Exploitation: Key ATT&CK Techniques	10
Celebrity Vulnerabilities Overview	11
Key Takeaways	20
Recommendations	21
HivePro Uni5: Your Threat Exposure Management Solution	22
Appendix	
1 – Glossary	23
2 – CVE Specifics	24
3 – References	29
What Next?	31

Defending the Spotlight

In today's evolving cybersecurity landscape, the emergence of celebrity vulnerabilities has elevated the urgency of safeguarding individuals, organizations, and even entire nations from potential threats.

This comprehensive report sheds light on the intricate realm of celebrity vulnerabilities, delving into their technical nuances, potential repercussions, and the underlying business implications they entail. As high-profile targets become magnets for cybercriminals seeking financial gain and recognition, a proactive cybersecurity approach becomes imperative. This report not only provides an overview of noteworthy celebrity vulnerabilities but also underscores the importance of embracing robust cybersecurity practices to mitigate risks effectively.

Furthermore, the report introduces HivePro's Uni5 Threat Exposure Management Platform as a strategic solution to bolster organizations' cybersecurity posture. By harnessing real-time monitoring, attack simulation, and streamlined remediation, Uni5 equips organizations to stay ahead of emerging threats and navigate the complex challenges posed by celebrity vulnerabilities. Through a proactive stance and innovative tools, businesses can fortify their operations, preserve their reputation, and proactively defend against evolving cyber threats.

Decoding Celebrity Vulnerabilities & understanding their Impact

Celebrity vulnerabilities encompass widely publicized software flaws that have had far-reaching and devastating consequences across various operating systems, software platforms, and hardware components.

The impacts of celebrity vulnerabilities are profound and multifaceted. They offer malicious actors an entry point into sensitive systems, potentially leading to unauthorized access and the compromise of critical information. The motives behind these attacks can range from data theft to outright system disruption. Consequently, the ramifications for businesses are grave, encompassing financial losses, reputational harm, and even legal ramifications.

To safeguard against the perils posed by celebrity vulnerabilities and the broader spectrum of cyber threats, businesses are compelled to adopt a proactive and comprehensive approach. Failure to do so can result in significant harm to the organization, including financial losses, reputational damage, legal liabilities, and regulatory fines. Businesses must ensure they are up-to-date with the latest patches and software updates, implement strong security measures, and educate their employees on the importance of cybersecurity hygiene. By taking these measures, businesses can mitigate the risks of celebrity vulnerabilities and protect themselves against cyber threats.

HiveForce Labs has undertaken an extensive examination of major celebrity vulnerabilities, unearthing the chaos they have engendered. This all-encompassing report serves to furnish both overarching insights and granular perspectives on these vulnerabilities, furnishing invaluable information to deepen comprehension and manage associated risks.

2023

Spring4Shell

CR8Escape

Follina

Oh Snap! More
Lemmings

SpoolFool

2022

Petit Potam

Chaos DB

Sequoia

Print

Nightmare

FragAttacks

NAME:WRECK

Baron Samedi

Log4Shell

OMI God

Hive

Nightmare

Proxy Shell

Bad Alloc

Proxy Logon

2021

BAD NEIGHBOR
INVDOS

Call Stranger

RECON

GHOST CAT

Curve Ball

SAD DNS

Container Drip

Zero Logon

SIG Red

Print Demon

SMB Ghost

Cable Haunt

2020

Zombie Load

Dirty Sock

Magellan 2.0

BlueKeep

2019

Double Kill

Drupalgeddon 2.0

Meltdown

Magellan

Spectre

Total
Meltdown

2018

Blue Borne

Cloudbleed

ROBOT

Samba Cry

Eternal
Blue

2017

Dirty Cow
Heist

2016

STAGEFRIGHT

GHOST

Bar Mitzvah

JASBUG

2015

Drupalgeddon

HeartBleed

Misfortune Cookie

Shellshock

2014

OH SNAP!
MORE LEMMINGS

LOG4J



Challenges Possessed by Celebrity Vulnerabilities

Publicity

Attacks on high-profile targets attract media attention, potentially tarnishing an organization's reputation and credibility. For example, the Equifax data breach in 2017 was a high-profile case where the company's reputation was severely damaged due to the publicity surrounding the attack. The breach exposed the personal information of millions of consumers, and Equifax faced widespread criticism for its handling of the incident.

Exploitation

Widely known vulnerabilities become prime targets for attackers, heightening the risk landscape for organizations. For example, the WannaCry ransomware attack in 2017 exploited a vulnerability in Microsoft's operating system that had been widely publicized months before the attack. The attack affected organizations worldwide and caused significant disruption and financial losses.

Mitigation

Applying patches for widespread vulnerabilities can be cumbersome, leaving systems exposed for extended periods. For example, the Heartbleed vulnerability in OpenSSL affected a large number of applications, and patching all of them was a time-consuming and challenging process. The vulnerability remained unpatched in many cases for years after it was first discovered, leaving many organizations vulnerable to attack.

Distractions

Overemphasis on celebrity vulnerabilities might divert attention from other critical yet less-publicized vulnerabilities.

Coordination

Vulnerabilities affecting multiple entities demand coordinated responses, often involving various stakeholders. For example, Supply Chain attacks such as SolarWinds 2020 attack

Insights

ZeroLogon

Patched in September 2020, Ranks in **Top 15** Exploited in 2021

2

Critical Windows Print Spooler Vulnerabilities - **PrintNightmare** & **PrintNightmare2**

200 Million

Cable Modems in Europe Alone Left Exposed by **Cable Haunt**

52,000 Systems Still at Risk:

BlueKeep Ranked **Ninth** among Most Exploited Vulnerabilities

HEARTBLEED

Vulnerability Persists After **8 Years**, Leaving Over **190K** Systems at Risk

Cyber Espionage Group

HAFNIUM

exploited zero-day vulnerability

PROXYLOGON

in Microsoft Exchange;

400K

exchange servers found vulnerable worldwide

21

Celebrity Vulnerabilities Outsmarted by Adversaries Despite Security Patches!

1 in 6 SPIRNG4SHELL vulnerable companies experienced exploitation attempts in just 4 days of vulnerability disclosure

Log4Shell

Endangered more than **3 billion devices**; 830K attack attempts with 45 exploit variants in Just 3 days

SPECTRE

vulnerability
resulted in losses
of **millions** of
dollars

200k computers in **150** countries hit by
WannaCry ransomware via **ETERNALBLUE**
vulnerability.

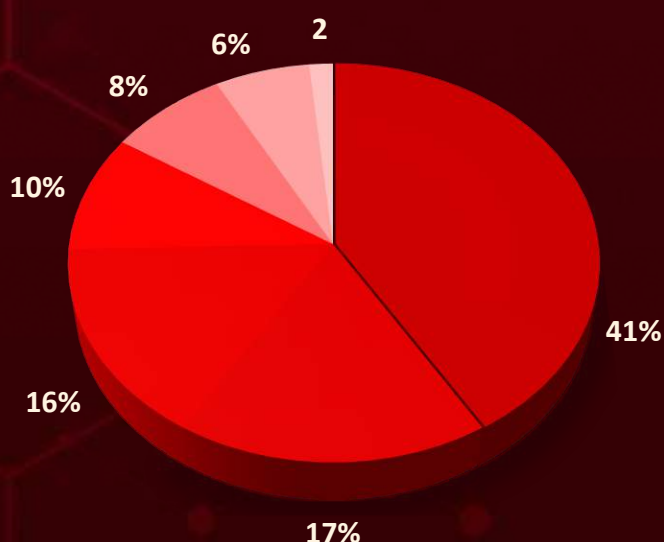
NAME:WRECK

Left **100** million
devices
susceptible

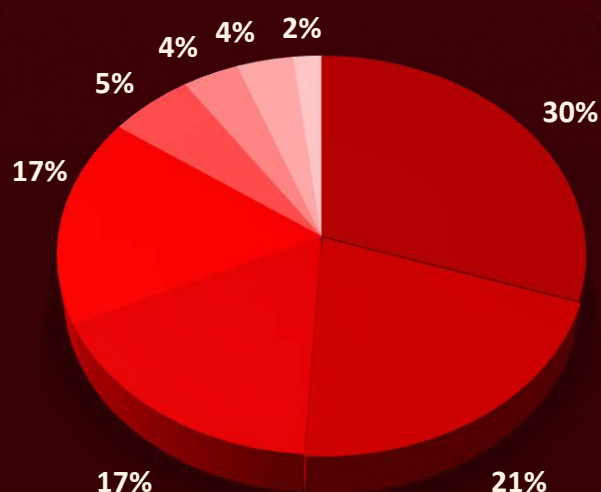
One in Four
Apache Downloads Involves
Unpatched Log4j Versions

950 Million Google Android Phones
Vulnerable: **Stagefright** Exploit Allows Hackers
to Hijack with Just One Text

Drupalgeddon
Threatened **1+**
million websites
for complete site
take over



**Distribution of vulnerabilities
by Attack Type**



**Distribution of vulnerabilities
by Attack Vector**

- Code Execution
- Privilege Escalation
- Account/System Takeover
- Arbitrary File Write
- Information Disclosure
- Denial of Service
- Spoofed Communication

- Vulnerable Service
- Local Exploitation
- Malicious Service
- Weak Cryptography
- Local Network Attack
- Malware
- Phishing
- Compromised Credentials

Exploring Exploitation: Key ATT&CK Techniques

T1059

Command and Scripting Interpreter

T1588.001

Malware

T1068

Exploitation for Privilege Escalation

T1499.004

Application or System Exploitation

T1562

Impair Defenses

T1553

Subvert Trust Controls

T1574

Hijack Execution Flow

T1565

Data Manipulation

T1203

Exploitation for Client Execution

T1566

Phishing

T1210

Exploitation of Remote Services

T1040

Network Sniffing

T1531

Account Access Removal

T1552

Unsecured Credentials

T1204

User Execution

T1565.001

Stored Data Manipulation

T1555

Credentials from Password Stores

T1098

Account Manipulation

T1005

Data from Local System

T1499

Endpoint Denial of Service

T1212

Exploitation for Credential Access

T1588.006

Vulnerabilities

T1548

Abuse Elevation Control Mechanism

T1587

Develop Capabilities

T1211

Exploitation for Defense Evasion

Celebrity Vulnerabilities Overview

FOLLINA : A remote code execution vulnerability in Microsoft Support Diagnostic Tool (MSDT) was dubbed as Follina and was given **CVE-2022-30190**. The adversaries used specially crafted macro-less MS Office document to invoke MSDT with external link, which downloads and executes malicious code. The attack chain only requires single user interaction of opening the document and MS Office “Protected View” security feature was ineffective in this attack chain.

SPRING4SHELL : Spring is a very popular Java-based application framework for web development and a remote code execution vulnerability was found in the heart of the framework. The vulnerability is caused by a flaw in the framework’s processing of HTTP requests, and which was used to deploy JSP web shell giving full access to adversary in the context of running java process. This vulnerability can be exploited remotely by sending a specially crafted HTTP request to a vulnerable server. This was dubbed as SpringShell or Spring4Shell and assigned **CVE-2022-22965** with Critical severity 9.8 CVSS v3 score.

CVE:	CVE-2022-22965	Name:	Remote Code Execution in MSDT
Severity	Critical	Zero-Day:	✓
Patch:	✓ Vendor Link	Exploit Available:	✓

SPOOLFOOL : A privilege escalation vulnerability was discovered in windows spooler service wherein an authenticated users while invoking add printer procedure can define a custom spool directory and may latch malicious dll. The issue was first reported in 2020 and was patched two times. In 2022, a new way of exploitation through remote printer add procedure was discovered and vulnerability was reported as **CVE-2022-21999** (SpoolFool). It affected all Windows Operating System and require local foot-print for exploitation.

CR8ESCAPE : cr8escape has a 8.8 severity rating and is allocated **CVE-2022-0811**, It affects Kubernetes with CRI-O container runtime engine implementation. Runtime engine performs all low-level task of creating, managing and running different images. The vulnerability allowed attacker with deployment rights to perform privilege escalation and execute arbitrarily code with root permissions.

PetitPotam : PetitPotam is an abuse of Encrypting File System Remote (EFSRPC) Protocol which was widely used with NTLM Relay techniques to take over Active Directory Certificate Services and finally domain controllers. A successful attack leads to unauthenticated user gain administrative privileges on Domain Controller. It is assigned **CVE-2021-36942**.

Log4Shell : Log4j is a widely integrated logging framework and is used to create application logs. The log text can be static like hardcodes in code or dynamic like user textbox input or HTTP request logs; Also, log4j resource lookup feature allow reference to external resources like LDAP, DNS lookup via java JNDI API. The vulnerability exists in the Log4j JNDI lookup wherein attacker can send crafted data with JNDI lookup, which enables them to download & execute custom code. This zero-day vulnerability had impacted products across entire IT ecosystem and led to widespread attack chains. It have **CVSS score of 10** and is assigned **CVE-2021-44228**. It was patched promptly; However, the patch was not sufficient, and a new Vulnerability dubbed **Log4Shell-2** with **CVE-2021-45046** and **CVSS score of 9** was reported soon, further adding to chaos. The new vulnerability can lead to data leak, RCE in certain configurations and local code injection in all configurations.

BadAlloc : BadAlloc is collection of more than 25 vulnerabilities impacting IoT, IIoT, ICS and embedded systems. The flaw was identified as improper input validation in memory allocation implementations. Without input validations, an attacker could exploit the memory allocation function to perform a heap overflow, resulting in execution of malicious code or system crash.

OMIGOD : Open Management Interface (OMI) is an Azure software agent pre-installed on Linux VM's in Azure. In 2021, OMI was found to be affected with unauthenticated remote code execution and three other privilege escalation vulnerability together dubbed as OMIGOD. The name is derived from expression O-MI-God as the exploitation is trivial, and it enables root privileges incase of missing Authentication header.

CVE:	CVE-2021-38647	Name:	Open Management Infrastructure Remote Code Execution Vulnerability
Severity:	Critical	Zero-Day:	
Patch:	 Vendor Link	Exploit Available:	

ChaosDB : A critical vulnerability on Microsoft Azure Cosmos database allowed complete account takeover and impacted 30% of Cosmo DB including number of Fortune 500 brands. The vulnerability may lead to complete control over any cosmos DB instance and had a trivial exploit via Jupyter notebook feature.

HiveNightmare (SeriousSAM) : HiveNightmare is referred to bad implementation of Access Control List in certain windows version which enables any standard user to access restricted registry hives like SAM, SECURITY and SYSTEM. Further, registry dumps are used to extract password and gain SYSTEM privileges. It is tracked with **CVE-2021-36934** and requires local foothold for exploitation.

PrintNightmare : A critical security vulnerability in Windows Point and Print feature of Spooler Service was discovered. Point and Print feature allows remote connection to printer and auto download of drivers. Both **CVE-2021-34527** and **CVE-2021-36958** were zero-day and dubbed as **PrintNightmare** and **PrintNightmare 2**. Exploitation of both vulnerabilities requires local foothold and lead to code execution with system privileges.

ProxyShell : ProxyShell is chain of three vulnerabilities comprising **CVE-2021-34473**, **CVE-2021-34523**, **CVE-2021-31207** and affecting on-premise Microsoft Exchange Setup. Microsoft Exchange is popular E-mail Service, and the vulnerability chain allows unauthenticated user to achieve remote code execution with SYSTEM privileges and take complete control of Exchange Servers. It was widely exploited by adversaries, and they were found to be deploying webshells, infiltrate internal network and installing Ransomware.

CVE:	CVE-2021-34473, CVE-2021-34523	Name:	Microsoft Exchange Server Privilege Escalation & RCE
Severity:	Critical	Zero-Day:	
Patch:	 Link1 , Link2	Exploit Available:	

Sequoia : An out-of-bounds write flaw was found in the Linux kernel Filesystem layer; the flaw was due to invalidated size_t to int conversion. This flaw allows a local standard user to gain access to out-of-bound memory, leading to a system crash or privilege escalation. It affected all versions of Linux and is assigned **CVE-2021-33909** with severity score of 7.8.

Baron Samedit : A buffer overflow vulnerability was found in Linux sudo program allowing any user to escalate privileges to root. sudo is a powerful program and allows to run command with privileges of other user. The vulnerability does not require user to be in sudoers group and successful exploitation will allow any user to gain root privilege. It was dubbed **Baron Samedit** with **CVE-2021-3156** and affected all Linux systems including 10 years old legacy systems.

ProxyLogon : ProxyLogon is a Microsoft Exchange Server vulnerability covered by **CVE-2021-26855**, **CVE-2021-26857**, **CVE-2021-26858**, and **CVE-2021-27065**; these four zero-day vulnerabilities are chained together to build an unauthenticated Remote Code Execution (RCE), allowing complete control of servers, steal email and plant further malware. It was attacked widely and 700+ successful web shell deployment were discovered.

NAME:WRECK : Multiple vulnerabilities were discovered in DNS implementation of FreeBSD, Ipnnet, NetX and Nucleus NET, impacting millions of devices worldwide. Successful exploitation of these vulnerabilities could cause either Denial of Service (DoS) or Remote Code Execution and they were dubbed together as NAME:WRECK.

RECON : The vulnerability, **CVE-2020-6287**, **Remotely Exploitable Code on NetWeaver (RECON)** with CVSS score of 10 affects a default component present in every SAP application running the SAP NetWeaver Java technology stack. The vulnerability lies in authentication process and can be exploited without any need of username and password. With successful exploitation, a new SAP user with maximum privileges can be created, bypassing all access and authorization controls and gaining full control of SAP systems.

FragAttacks : Several vulnerabilities related to Wi-Fi design and implementation were discovered and together termed as FragAttacks, affecting all the Wifi-devices. The exploitation requires attacker to be in range, thus making it difficult to scale. Successful exploitation could lead to data interception, system disruption or code execution in certain implementation.

SAD DNS : A vulnerability in DNS implementation were identified which allowed DNS cache poisoning by leveraging network side channels, thus allowing an attacker to inject malicious DNS records into a DNS cache causing attacker to eavesdrop and tampering with the communication. It is dubbed as Side-channel Attacked DNS aka SAD DNS and was assigned CVE-2020-25705.

Ghostcat : Ghostcat is a critical vulnerability in the Apache Tomcat web server that could allow attackers to read sensitive configuration files or execute arbitrary code. It was caused by a flaw in the implementation of the Apache JServ Protocol (AJP) connector, which is used to communicate between Tomcat and other web servers and is enabled by default. It is tracked with CVE-2020-1938 and given CVSS score of 9.8.

CVE:	CVE-2020-1938	Name:	Apache Tomcat Improper Privilege Management Vulnerability
Severity:	Critical	Zero-Day:	
Patch:	 Vendor Link	Exploit Available:	

Bad Neighbor : This is a serious Remote Code Execution vulnerability exists when the Windows TCP/IP stack improperly handles ICMPv6 Router Advertisement packets allowing an attacker to execute arbitrary code and take over a machine simply by sending a specially crafted packet to a vulnerable system. This vulnerability relates to IPv6 Neighbor Discovery Protocol, hence dubbed 'Bad Neighbor' and is being tracked with CVE-2020-16898.

ContainerDrip: A bug was discovered in container image pulling process of containerd tool; containerd is an industry-standard container runtime and is used by Docker, Kubernetes CRI and in few other projects. The bug leaks credential and other registry-specific HTTP headers if it encounters HTTP 401 status code while fetching images. The vulnerability is tagged with CVE-2020-15157.

CallStranger : A Vulnerability in the Universal Plug and Protocol (UPnP) affected billion of devices worldwide; UPnP is used to provide automatic discovery of devices, lacks authentication or verification and is intended to be used in trusted networks. Successful exploitation can lead to Data exfiltration, turn exposed UPnP device into a bot for coordinated DDoS attacks, and scan internal networks. It is assigned CVE-2020-12695.

ZeroLogon : A vulnerability related to domain logon process was discovered allowing privilege escalation. The flaw was exploited by setting initialisation vector (IV) to all zeros, instead of a random number, thus it was dubbed as ZeroLogon and assigned **CVE-2020-1472**. The vulnerability is very severe with **CVSS score of 10** since the only requirement for a successful exploit is the ability to establish a connection with a domain controller. The unauthenticated attacker can establish a vulnerable Netlogon session and gain domain administrator privileges.

CVE:	CVE-2020-1472	Name:	NetLogon Privilege Escalation Vulnerability
Severity:	Critical	Zero-Day:	
Patch:	 Vendor Link	Exploit Available:	

SIGRed : A 17-year-old flaw in windows DNS server was discovered in 2020 which can be triggered by a malicious DNS response, the vulnerability is assigned **CVE-2020-1350** with **severity score of 10** and has high likelihood of exploitability. The vulnerability exists in a function that parses the SIG queries, thus dubbed as SIGRed. The vulnerability can even be exploited remotely through HTTP payload and is tagged as wormable; referring to its capability to infect other vulnerable machines in network without any need of user interaction.

CVE:	CVE-2020-1350	Name:	Microsoft Windows DNS Server Remote Code Execution Vulnerability
Severity:	Critical	Zero-Day:	
Patch:	 Vendor Link	Exploit Available:	

PrintDemon : A local privilege elevation vulnerability was discovered in windows spooler service and was dubbed as PrintDemon with **CVE-2020-1048**; the vulnerability allows arbitrary file writing via windows API anywhere on the operating system. Successful exploitation may lead to deployment of webshells.

SMBGhost (SMBleedingGhost or CoronaBlue) : A wormable vulnerability was reported in SMBv3 affecting Windows Server and endpoint, it is assigned **CVE-2020-0796** with **CVSS score of 10**. SMB enables shared access to files and other assets within a network. Exploitation can be done by sending a specially crafted packet to a vulnerable system causing the system to crash or execute arbitrary code.

CVE:	CVE-2020-0796	Name:	Microsoft SMBv3 Remote Code Execution Vulnerability
Severity:	Critical	Zero-Day:	
Patch:	 Vendor Link	Exploit Available:	

Curveball : Curveball is certificate validation bug in cryptographic module crypt32 and affects Windows TLS, code signing process. It can be exploited by creating a malicious ECC certificate that appears to be signed by a trusted root authority and can be used for delivery of false website certificates or attacker may sign malware to appear legitimate win executable. It is assigned **CVE-2020-0601**.

Cable Haunt : Millions of modems worldwide were affected by a vulnerability enabling attackers to gain complete access over modem. The attacker can tamper with firmware, cause DoS or spoof communication. The vulnerability was found in Broadcom chip which exposes unsecured WebSockets interface reachable via JavaScript in a victim's browser. It was dubbed as Cable Haunt and assigned **CVE-2019-19494**.

Dirty Sock : Dirty Sock is a local privilege escalation flaw in Ubuntu snap package manager. The vulnerability was due to a bug in the snapd API, a default service. Exploitation requires a local foothold and can lead to root access to the system. It is assigned **CVE-2019-7304**.

Magellan : In 2018, 3 set of vulnerabilities dubbed as **Magellan 1.0** were discovered in SQLite which is an embedded database usually integrated with different apps like Google Chrome. The vulnerability was caused by improper input validation in SQL commands received from integrated apps and can lead to remote code execution in certain implementations. In 2109 again, 5 set of vulnerabilities were discovered in SQLite and dubbed as **Magellan 2.0**; both Magellan 1.0 and 2.0 critically affected Google Chrome.

Zombieload : A vulnerability related to CPU speculative execution process was discovered; the speculation process helps in speeding up the processing time however there was ways to obtain data from various CPU buffer zones and data processing operations. Successful exploitation may lead to leak of sensitive data. It was dubbed as Zombieload and assigned **CVE-2018-12130**. A year later in 2019, a similar vulnerability was found which was dubbed as Zombieload 2 and assigned **CVE-2019-11135**.

Bluekeep : A Remote Code Execution vulnerability in windows Remote Desktop Protocol (RDP) having **9.8 CVSS score** was discovered in 2019, it was named Bluekeep and assigned **CVE-2019-0708**. It is wormable and can be exploited without any auth data, successful exploitation can lead to complete system take over.

CVE:	CVE-2019-0708	Name:	Remote Code Execution in Windows Remote Desktop Services
Severity:	Critical	Zero-Day:	
Patch:	 Vendor Link	Exploit Available:	

Double Kill : Double Kill, **CVE-2018-8174**, is a **zero-day vulnerability** in the Microsoft VBScript engine and it was discovered during active exploitation by multiple APT actors. The vulnerability is caused by a failure in the way the VBScripts engine handles objects in memory and multiple windows product were found to be affected by this. Successful exploitation could lead to remote code execution.

InvDos : InvDoS is an easily exploitable, classical Denial of Service attack on bitcoin nodes; DoS happens due to uncontrolled consumption of the node memory resources while processing malformed Bitcoin transactions, it is assigned **CVE-2018-17145** and affected 50% of active nodes at the time of discovery.

Drupalgeddon : Two vulnerabilities were discovered on Drupal which is a web content management system used to build websites. **Drupalgeddon1**, **CVE-2014-3704**, vulnerability existed in the Drupal core's SQL query builder, enabling malicious code injection leading to unauthorized access to the website. **Drupalgeddon2**, **CVE-2018-7600**, with **CVSS score of 9.8** existed due to insufficient input validation on the Drupal 7 Form API leading to remote code execution.

Spectre : Spectre vulnerability was found in CPU Speculative Execution; speculative execution is an optimization technique of predicting & executing next instruction code in advance to utilize free CPU cycles. It is assigned **CVE-2017-5753** and tricks processor to load sensitive data of other program into cache which can be read by another malicious program leading to data leak. Spectre patches were said to be affecting CPU performance.

Cloudbleed : **Cloudflare**, a CDN provider, edge servers were affected by a bug leading to leak of information passing through them. The information includes HTTP cookies, authentication tokens, HTTP POST bodies, and other sensitive data. Much of this information was also cached by search engines.

Meltdown : Meltdown vulnerability was also found in CPU Speculative Execution Process. The vulnerability broke the gap between user process and OS process, allowing user process to read kernel memory leading to data leak. It is assigned **CVE-2017-5754**. The patches for Meltdown gave birth to new more severe vulnerability termed as **Total Meltdown**, which allowed any process to read/write in the complete memory leading to data leak and code injection. It is tracked with **CVE-2018-1038**.

SambaCry : **CVE-2017-7494**, is a remote code execution vulnerability in samba allowing attacker having valid write access to a file share to upload a binary library which then gets loaded and executed by the server. Samba is used for file and print sharing through SMB protocol. Successful exploitation could lead to unauthorized access, data theft, or full control over the affected system.

CVE:	CVE-2017-7494	Name:	Insecure library loading in Samba
Severity:	Critical	Zero-Day:	
Patch:	 Vendor Link	Exploit Available:	

ROBOT : A vulnerability was detected in TLS protocol while using RSA for key exchange, the vulnerability allows decryption of cipher text fully breaking the TLS confidentiality. This vulnerability affected numerous popular vendors and software solutions, including Cisco, Citrix, F5, IBM, PaloAlto and tracked through numerous CVE.

BlueBorne : BlueBorne is a set of vulnerabilities in the Bluetooth protocol and its implementation affecting various operating systems, including Android, Windows, and Linux. The vulnerabilities allowed attackers to remotely execute code, access sensitive data, and spread malware between devices without user interaction.

EternalBlue : In May 2017, the WannaCry ransomware attack shook the world affecting hundreds of thousands of computers in over 150 countries. The attack exploited a vulnerability in Microsoft Windows SMBv1 implementation and allowed attackers to remotely execute arbitrary code and gain network access by sending specially crafted packets. It is tracked with **CVE-2017-0144**.

HEIST : A vulnerability in HTTPS protocol termed as HEIST, **HTTP Encrypted Information can be Stolen Through TCP-Windows**, enabled attackers to guess the length of HTTP response and thus facilitating HTTP decompression attacks like CRIME, BREACH. It can lead to browser data leakage directly via javascript and is being tracked with **CVE-2016-7152**.

Dirty COW : Dirty COW, **CVE-2016-5195**, is a critical security flaw in the Linux kernel that could allow an attacker to gain root access to a vulnerable system. The attack exploits a race condition vulnerability in the copy-on-write (COW) mechanism of the kernel's memory management subsystem, allowing an attacker to write to read-only memory pages and execute malicious code. The vulnerability affects most Linux distributions, including Ubuntu, Debian, and Red Hat. It requires local foothold for exploitation.

Bar Mitzvah : A vulnerability in RC4 algorithm used in SSL/TLS protocol could allow a remote attacker to obtain sensitive information. It is termed as Bar Mitzvah and tracked with **CVE-2015-2808**. Attacker can obtain sensitive details by sniffing the traffic and does not necessarily be Man in the Middle.

Oh Snap! More Lemmings : Snap is a software packaging and deployment system available in Linux systems and by default enabled in Ubuntu, a race-condition leading to privilege escalation exists in snap-confine which is used internally by snap daemon to construct the execution environment for snap applications. An unprivileged user can gain root privileges and take complete control of system. **CVE-2021-44731** is assigned with CVSS v3 score of 7.8.

STAGEFRIGHT : A **CVSS score 10** vulnerability in libstagefright library affecting Android OS allows remote attackers to perform arbitrary operations on the victim's device. It can be easily exploited by sending crafted MMS messages to the victim device and mostly requires no end-user actions upon message reception to succeed.

GHOST : **CVE-2015-0235**, is a critical vulnerability with **CVSS score of 10** in gethostbyname function of glibc library. It allows an unauthenticated user to completely takeover the system; some of the attack vectors are very trivial and can be easily exploited only by sending a crafted DNS request.

JASBUG : The JASBUG vulnerability hijacks the NetLogon and SMB request that clients and servers make during the Group Policy refresh in Microsoft Active Directory environment. The attack involves deceiving a client to receive rogue policies, allowing attacker to remotely take control of system. It is tracked with **CVE-2015-0008**.

Misfortune COOKIE : A critical vulnerability with CVSS score of 10, tracked as CVE-2014-9222, was discovered in multiple firmware's affecting 12 million devices worldwide. This vulnerability could be trivially exploited by sending a HTTP request with cookie attribute containing code to be executed. The vulnerability cause execution of cookie content as command and lead to remote code execution.

SHELLShock (BashDoor) : A vulnerability, CVE-2014-6271, found in the Bash shell allowing attackers to remotely execute arbitrary code on the system and potentially gaining complete control over it. Bash is a commonly used Linux command-line interpreter, and the vulnerability is caused by a flaw in how Bash handles environment variable. The vulnerability affects a wide range of systems, including web servers, routers, and other network devices.

CVE:	CVE-2014-6271	Name:	QNAP QTS flaw in the GNU Bash shell
Severity:	Critical	Zero-Day:	
Patch:	 Vendor Link	Exploit Available:	

Heartbleed : A vulnerability, CVE-2014-0160, in the OpenSSL allowed attackers to read sensitive information from the memory of affected systems, including usernames, passwords, and other sensitive data. Attacker can exploit vulnerability by sending a malformed heartbeat message to target server, causing server to disclose sensitive information from its memory. It affected wide-range of systems including web servers, email servers, and number of Internet-connected devices that use OpenSSL.

Refer [Appendix 2](#) of the document for CVE details.

Key Takeaways

#1

Business Consequences- Exploitation of celebrity vulnerabilities can lead to financial losses, reputation damage, legal liabilities, and regulatory fines for businesses and can have devastating consequences across various operating systems, software platforms, and applications.

#2

Proactive Approach- To mitigate the risks of celebrity vulnerabilities and other cyber threats, businesses must adopt a proactive and comprehensive cybersecurity approach.

#3

Impact-Driven Remediation- Implement a remediation approach driven by potential impact, requiring collaboration between IT and security teams.

#4

Continuous Monitoring- Regularly assess the effectiveness of network and endpoint security controls to adapt to evolving threats.

#5

Chaining Vulnerabilities- Adversaries are increasingly chaining vulnerabilities, making it essential to prioritize patching based on potential impact rather than just severity.

#6

Accessibility of Exploits- Some vulnerabilities are easily exploitable, enabling less sophisticated adversaries to launch attacks, emphasizing the importance of addressing even seemingly low-severity issues.

Recommendations

#1

Leverage Cybersecurity Solutions- Explore the adoption of cybersecurity solutions, such as HivePro's Uni5 Threat Exposure Management Platform, to streamline vulnerability identification, real-time monitoring, and remediation efforts effectively.

#2

Regular Vulnerability Assessments and Security Audits- Conduct regular vulnerability assessments, penetration testing, and security audits to identify and address vulnerabilities, potential weaknesses, and ensure ongoing protection, including celebrity vulnerabilities, before they can be exploited.

#3

Regular Training and Drills- Conduct regular training sessions and simulated attack drills to educate employees about recognizing and responding to potential vulnerabilities and cyber threats.

#4

Supply Chain Security- Assess and monitor the cybersecurity practices of third-party vendors and partners to reduce the risk of supply chain attacks.

#5

Incident Response Plan- Develop and regularly update an incident response plan that outlines steps to take in the event of a cybersecurity incident, including a breach involving celebrity vulnerabilities.

#6

Effective Communication, Collaboration, and Patch Management- Foster communication and collaboration between IT teams and senior management to ensure awareness of potential vulnerabilities, secure necessary resources for mitigation, and establish a robust patch management strategy that prioritizes timely security updates and patches for all software and systems.

HivePro Uni5: Your Threat Exposure Management Solution

Using HivePro's Uni5 Threat Exposure Management Platform can provide significant benefits to organizations in addressing celebrity vulnerabilities, including a remarkable reduction in risk KPIs, an increase in operational KPIs, and a reduced financial exposure.

Firstly, Uni5's vulnerability as a data pivot approach enables organizations to identify and prioritize vulnerabilities that pose the greatest risk, including celebrity vulnerabilities. By focusing on the most critical vulnerabilities, Uni5 helps organizations reduce their overall risk exposure, which can result in a remarkable reduction of risk KPIs.

Secondly, the Uni5 platform provides real-time monitoring and attack simulation capabilities that can help organizations improve their operational KPIs. With the ability to quickly identify and respond to potential threats, organizations can improve their response times and minimize the impact of attacks on their systems and data.

Finally, by reducing the risk exposure and improving operational KPIs, organizations can also reduce their financial exposure. By mitigating the potential impact of celebrity vulnerabilities, organizations can avoid financial losses, legal liabilities, and reputational damage, which can result in significant cost savings.

For example, let's say a company experiences a data breach due to a celebrity vulnerability that was not properly addressed. This could result in financial losses ranging from hundreds of thousands to millions of dollars due to lost business, legal fees, and fines. Additionally, the company's reputation could be damaged, resulting in a decrease in customer trust and loyalty, leading to an estimated 20% decrease in revenue in the following year.

In conclusion, using HivePro's Uni5 Threat Exposure Management Platform is a smart business decision for organizations looking to address celebrity vulnerabilities. By reducing risk exposure, improving operational KPIs, and minimizing financial exposure, Uni5 can provide a significant return on investment while also protecting the organization from potential cyber threats.

Appendix 1

Glossary:

Attack Type: Attack Type refers to the specific kind of malicious activity or action that an adversary can achieve by successfully exploiting a vulnerability. It reflects the primary outcome resulting from the exploitation aspect of a vulnerability.

Attack Vector: An attack vector refers to the specific method through which a cyber attack is carried out on a system, network, or application. It represents the entry point or vulnerability that an attacker exploits to gain unauthorized access, compromise data, or disrupt normal operations.

Compromised Credentials – Attacks requiring credential access to service for exploitation.

Local Exploitation – Vulnerabilities can be exploited only after getting local foothold.

Local Network Attack – Vulnerabilities which can be exploited in Intranet or by being in Radio range.

Malicious Service/ Website – Vulnerabilities which requires user connection to malicious domain to inject script for exploiting it.

Vulnerable Service/ WebApp – Vulnerabilities which is exploited directly by adversary.

Worm – Vulnerabilities resulting in system compromise can trigger automatic propagation to other vulnerable systems.

CVE - Common Vulnerabilities and Exposures

Appendix 2

Name	CVE	AFFECTED PRODUCT	Attack Type	Attack Vector
Follina	CVE-2022-30190	Microsoft Windows	Remote Code Execution	Phishing
Spring4Shell	CVE-2022-22965	Multiple WebApps - Including Inhouse developed & COTS	Remote Code Execution	Vulnerable WebApp
SpoolFool	CVE-2022-21999	Microsoft Windows	Privilege Escalation	Malware
CR8Escape	CVE-2022-0811	CRI-O, OpenShift, Kubernetes	Local Code Execution	Local Exploitation
Oh Snap! More Lemmings	CVE-2021-44731	Snap, Ubuntu, Debian, Fedora	Privilege Escalation	Malware
Log4Shell	CVE-2021-45046 CVE-2021-44228	Log4j and Integrated Products	Remote Code Execution	Vulnerable WebApp
OMI God	CVE-2021-38647 CVE-2021-38645 CVE-2021-38648 CVE-2021-38649	Azure Platform	Remote Code Execution Privilege Escalation	Vulnerable Service
ChaosDB	Cloud	Azure Cosmos DB	Account Takeover	Vulnerable WebApp
Petit Potam	CVE-2021-36942	Microsoft Windows	Account Takeover	Local Network Attack
Hive Nightmare	CVE-2021-36934	Microsoft Windows	Privilege Escalation	Malware
Print Nightmare	CVE-2021-34527 CVE-2021-36958	Microsoft Windows	Remote Code Execution	Local Network Attack
Proxy Shell	CVE-2021-34473 CVE-2021-34523 CVE-2021-31207	Microsoft Exchange	Access Control Bypass Privilege Escalation Remote Code Execution	Compromised Credentials
Sequoia	CVE-2021-33909	Linux sub-system	Denial of Service Privilege Escalation	Local Exploitation
Baron Samedit	CVE-2021-3156	Linux sub-system	Privilege Escalation	Local Exploitation

Name	CVE	AFFECTED PRODUCT	Attack Type	Attack Vector
Bad Alloc	CVE-2021-30636 CVE-2021-27431 CVE-2021-27433 CVE-2021-27435 CVE-2021-27427 CVE-2021-22684 CVE-2021-27439 CVE-2021-27425 CVE-2021-26461 CVE-2020-35198 CVE-2020-28895 CVE-2021-31571 CVE-2021-31572 CVE-2021-27417 CVE-2021-3420 CVE-2021-27411 CVE-2021-26706 CVE-2021-27421 CVE-2021-22680 CVE-2021-27419 CVE-2021-27429 CVE-2021-22636 CVE-2021-27504 CVE-2021-27502 CVE-2021-22156 CVE-2020-13603	IIoT, embedded systems and RTOS of Amazon, Blackberry, Google, Samsung, Texas Instruments	Denial of Service Privilege Escalation	Local Exploitation
Proxy Logon	CVE-2021-26855 CVE-2021-26857 CVE-2021-26858 CVE-2021-27065	Microsoft Exchange	Unauthenticated Remote Code Execution	Vulnerable WebApp
NAME:WRECK	CVE-2021-25677 CVE-2020-27009 CVE-2020-15795 CVE-2020-27738 CVE-2020-27736 CVE-2020-27737 CVE-2016-20009 CVE-2020-7461	FreeBSD, IpNet, NetX, Nucleus Net	Denial of Service Remote Code Execution	Vulnerable Service
RECON	CVE-2020-6287	SAP NetWeaver Apps	Unauthenticated Remote Code Execution	Vulnerable WebApp
SAD DNS	CVE-2020-25705	Linux sub-system	Traffic Interception	Malware
GHOST CAT	CVE-2020-1938	Apache Tomcat	Code Execution	Vulnerable WebApp

Name	CVE	AFFECTED PRODUCT	Attack Type	Attack Vector
FragAttacks	CVE-2020-26145 CVE-2020-26144 CVE-2020-26140 CVE-2020-26143 CVE-2020-24588 CVE-2020-24587 CVE-2020-24586 CVE-2020-26139 CVE-2020-26146 CVE-2020-26147 CVE-2020-26142 CVE-2020-26141	All Wi-Fi Implementations	Traffic Interception Code Execution	Local Network Attack
BAD NEIGHBOR	CVE-2020-16898	Microsoft Windows	Code Execution	Local Network Attack
Container Drip	CVE-2020-15157	Containerd Runtime, Kubernetes, Docker	Credential Theft	Malicious Service
Zero Logon	CVE-2020-1472	Microsoft Windows	Privilege Escalation	Local Network Attack
SIG Red	CVE-2020-1350	Microsoft Windows	Remote Code Execution	Worm
Call Stranger	CVE-2020-12695	UPnP Implementations	Data Exfiltration Denial of Service	Vulnerable Service
Print Demon	CVE-2020-1048	Microsoft Windows	File Write	Vulnerable Service
SMB Ghost	CVE-2020-0796	Microsoft Windows	Code Execution	Worm Local Network Attack
Curve Ball	CVE-2020-0601	Microsoft Windows	Executable Spoofing	Malware
Dirty Sock	CVE-2019-7304	Ubuntu	Privilege Escalation	Local Exploitation
Cable Haunt	CVE-2019-19494	Modems - Multiple OEM	Denial of Service Spoofing	Local Network Attack
Magellan	CVE-2018-20346 CVE-2018-20505 CVE-2018-20506 CVE-2019-13734 CVE-2019-13750 CVE-2019-13751 CVE-2019-13752 CVE-2019-13753	SQLite, Google Chrome	Code Execution	Malicious Service
Zombie Load	CVE-2018-12130 CVE-2019-11135	Intel CPU	Information Disclosure	Local Exploitation
BlueKeep	CVE-2019-0708	Microsoft Windows	System Takeover	Worm
Double Kill	CVE-2018-8174	Microsoft Windows	Remote Code Execution	Phishing

Name	CVE	AFFECTED PRODUCT	Attack Type	Attack Vector
Drupalgeddon	CVE-2014-3704 CVE-2018-7600	Drupal	Data Exfiltration Remote Code Execution	Vulnerable WebApp
INVDos	CVE-2018-17145	Bcoin, Bitcoin, Litecoin, Namecoin	Denial of Service	Vulnerable Service
Spectre	CVE-2017-5753	Intel CPU	Information Disclosure	Local Exploitation
Melt Down	CVE-2017-5754 CVE-2018-1038	Intel CPU	Information Disclosure Code Injection	Local Exploitation
Cloudbleed	Cloud	Cloudflare	Information Disclosure	Vulnerable Service
Samba Cry	CVE-2017-7494	Samba	Remote Code Execution	Malware
ROBOT	CVE-2018-9192 CVE-2018-9194 CVE-2016-6883 CVE-2012-5081 CVE-2017-6168 CVE-2018-1388 CVE-2018-5762 CVE-2017-17382 CVE-2017-17427 CVE-2017-17428 CVE-2017-12373 CVE-2017-13098 CVE-2017-13099 CVE-2017-17841 CVE-2017-18268 CVE-2017-15533 CVE-2017-1000385	Citrix ADC Citrix Gateway Cisco ACE Cisco ASA PAN OS IBM GSKit Symantec SSLV Fotiguard VIP SSL Aruba Instant Radware Alteon	Information Disclosure	Weak Cryptography
Blue Borne	CVE-2017-8628 CVE-2017-1000251 CVE-2017-1000252	Microsoft Windows Linux Subsystems	Remote Code Execution	Worm Local Network Attack
Eternal Blue	CVE-2017-0144	SMB Protocol Microsoft Windows	Remote Code Execution	Worm Local Network Attack
HEIST	CVE-2016-7152	HTTPS Protocol All Browsers	Information Disclosure	Malicious Website
DirtyCOW	CVE-2016-5195	Linux sub-systems	Code Execution	Local Exploitation
Bar Mitzvah	CVE-2015-2808	SSL/TLS Protocol	Information Disclosure	Weak Cryptography

Name	CVE	AFFECTED PRODUCT	Attack Type	Attack Vector
STAGEFRIGHT	CVE-2015-1538 CVE-2015-1539 CVE-2015-3824 CVE-2015-3826 CVE-2015-3827 CVE-2015-3828 CVE-2015-3829 CVE-2015-3864 CVE-2015-6602	Android	Remote Code Execution	Vulnerable Service
GHOST	CVE-2015-0235	Glibc Implementations	System Takeover	Vulnerable Service
JASBUG	CVE-2015-0008	Microsoft Windows	System Takeover	Local Network Attack
Misfortune Cookie	CVE-2014-9222	SOHO Routers	Remote Code Execution	Local Network Attack
Shellshock	CVE-2014-6271	Linux Sub-systems	Remote Code Execution	Vulnerable Service
Heartbleed	CVE-2014-0160	OpenSSL Simatic Firmware Intellian Firmware Fedora, Redhat, Ubuntu	Information Disclosure	Malware

Appendix 3

References

<https://msrc.microsoft.com/blog/2022/05/guidance-for-cve-2022-30190-microsoft-support-diagnostic-tool-vulnerability/>

<https://spring.io/security/cve-2022-22965>

<https://research.ifcr.dk/spoolfool-windows-print-spooler-privilege-escalation-cve-2022-22718-bf7752b68d81>

<https://www.crowdstrike.com/blog/cr8escape-new-vulnerability-discovered-in-cri-o-container-engine-cve-2022-0811/>

<https://www.qualys.com/2022/02/17/cve-2021-44731/oh-snap-more-lemmings.txt>

<https://logging.apache.org/log4j/2.x/security.html>

<https://www.wiz.io/blog/omigod-critical-vulnerabilities-in-omi-azure>

<https://chaosdb.wiz.io/>

<https://labs.k7computing.com/index.php/the-petitpotam-story/>

<https://msrc.microsoft.com/update-guide/vulnerability/CVE-2021-36934>

<https://blog.sygnia.co/demystifying-the-print-nightmare-vulnerability>

<https://www.mandiant.com/resources/blog/pst-want-shell-proxyshell-exploiting-microsoft-exchange-servers>

<https://blog.qualys.com/vulnerabilities-threat-research/2021/07/20/sequoia-a-local-privilege-escalation-vulnerability-in-linux-filesystem-layer-cve-2021-33909>

<https://blog.qualys.com/vulnerabilities-threat-research/2021/01/26/cve-2021-3156-heap-based-buffer-overflow-in-sudo-baron-samedit>

<https://msrc.microsoft.com/blog/2021/04/badalloc-memory-allocation-vulnerabilities-could-affect-wide-range-of-iot-and-ot-devices-in-industrial-medical-and-enterprise-networks/>

<https://cyble.com/blog/proxylogon-vulnerability-a-cybersecurity-nightmare/>

<https://www.forescout.com/research-labs/namewreck/>

<https://onapsis.com/recon-sap-cyber-security-vulnerability>

<https://www.fragattacks.com/>

<https://www.saddns.net/>

<https://www.chaitin.cn/en/ghostcat>

<https://www.mcafee.com/blogs/other-blogs/mcafee-labs/cve-2020-16898-bad-neighbor/>

<https://blog.aquasec.com/cve-2020-15157-containerd-container-vulnerability>

<https://www.secura.com/uploads/whitepapers/Zerologon.pdf>

<https://research.checkpoint.com/2020/resolving-your-way-into-domain-admin:-exploiting-a-17-year-old-bug-in-windows-dns-servers/>

<https://www.tenable.com/blog/cve-2020-12695-callstranger-vulnerability-in-universal-plugin-and-play-upnp-puts-billions-of>

<https://windows-internals.com/printdemon-cve-2020-1048/>

<https://vulcan.io/blog/what-is-smbghost-vulnerability-and-how-to-fix-it/>

<https://www.trellix.com/en-us/about/newsroom/stories/research/curveball-an-unimaginative-pun-but-a-devastating-bug.html>

<https://shenaniganslabs.io/2019/02/13/Dirty-Sock.html>

<https://cablehaunt.com/>

<https://threatpost.com/google-chrome-affected-by-magellan-2-0-flaws/151446/>

<https://zombieloadattack.com/>

<https://www.opswat.com/blog/bluekeep-detecting-and-remediating-a-critical-and-wormable-remote-code-execution-vulnerability>

<https://www.bitdefender.com/blog/businessinsights/double-kill-a-prodigy-of-zero-days-and-what-we-can-learn-from-it/>

<https://cyware.com/news/what-is-drupalgeddon-and-what-kind-of-targets-does-it-go-after-78f558ec>

<https://invdos.net/>

<https://meltdownattack.com/>

<https://blog.cloudflare.com/incident-report-on-memory-leak-caused-by-cloudflare-parser-bug/>

<https://securelist.com/smbacry-is-coming/78674/>

<https://robotattack.org/>

<https://www.armis.com/research/blueborne/>

<https://www.avast.com/c-eternalblue>

<https://community.f5.com/t5/technical-articles/heist-vulnerability-overview-and-big-ip-mitigation/ta-p/278070>

<https://dirtycow.ninja/>

<https://www.secpod.com/blog/cve-2015-2808-bar-mitzvah-attack-in-rc4-2/>

<https://www.zimperium.com/blog/experts-found-a-unicorn-in-the-heart-of-android/>

<https://blog.qualys.com/vulnerabilities-threat-research/2015/01/27/the-ghost-vulnerability>

<https://blogs.manageengine.com/active-directory/admanager/2015/06/19/protecting-active-directory-from-the-jasbug-vulnerability.html>

<https://blog.checkpoint.com/security/misfortune-cookie-the-hole-in-your-internet-gateway-3/>

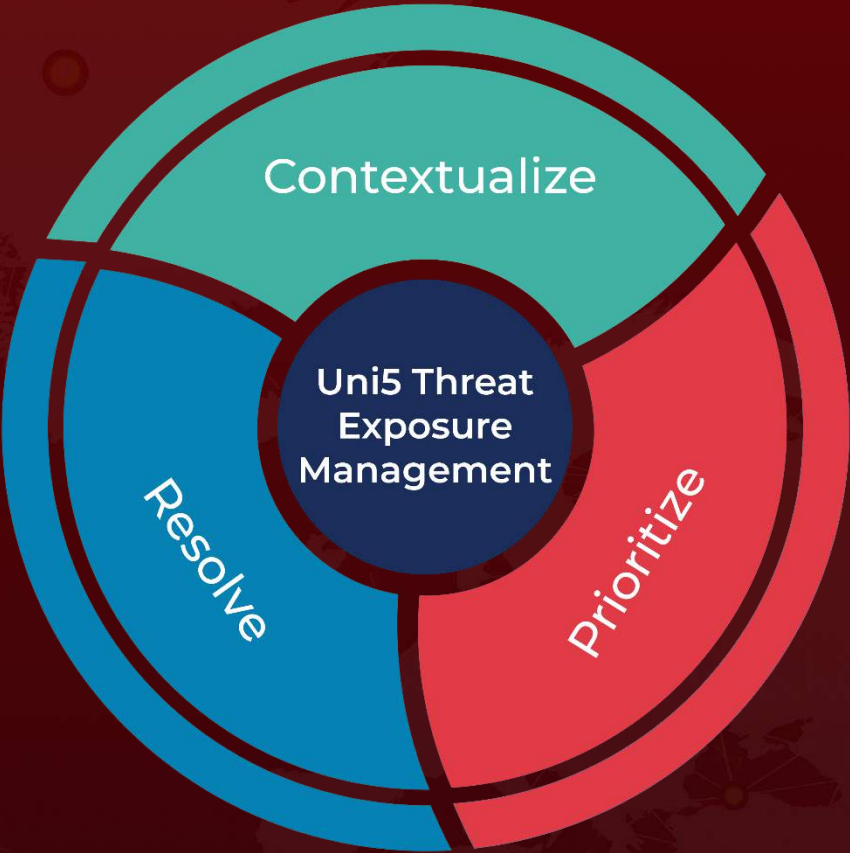
<https://blog.cloudflare.com/inside-shellshock/>

<https://heartbleed.com/>

What Next?

At Hive Pro, it is our mission to detect the most likely threats to your organization and to help you prevent them from happening.

Try Now for free or Book a free demo with HivePro Uni5: Threat Exposure Management Platform.



REPORT GENERATED ON
September 14, 2023 • 09:00 PM

